

LAB 08

DataCore - Backup, Disaster Recovery ve Business Continuity

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: Technology Risk Analyst

1. HİKÂYE

Sektör Veri analitiği hizmetleri	Ölçek 920 çalışan, 120 kurumsal müşteri
Ortam İki veri merkezi, AWS arşiv, SaaS bağımlılıkları	Kritik hizmet Gerçek zamanlı müşteri raporlama platformu

DataCore yönetimi felaket halinde kritik hizmetlerin dört saat içinde döneceğini müşterilerine bildirmektedir. Son kapasite toplantısında ikinci veri merkezinin bazı sistemler için pasif durumda olduğu anlaşılmıştır. Yönetim, yedekleme başarı oranını %99,2 olarak raporladığı için önemli bir risk görmemektedir. Siz Yönetim Kurulunun talebiyle yedekleme, felaket kurtarma ve iş sürekliliği bütünlüğünü incelemektesiniz.

2. SİZE VERİLEN GÖREV

Yedek alınması, verinin geri getirilebilmesi ve iş hizmetinin kabul edilebilir sürede çalışması arasındaki farkları kanıtlarla değerlendirin.

3. OLAYLAR VE KANITLAR

E-01 | BIA 2022

Raporlama platformu RTO 4 saat, RPO 15 dakika; faturalama RTO 24 saat; kimlik servisi RTO 8 saat. Yeni müşteri veri aktarım servisi BIA'ya eklenmemiştir.

E-02 | Yedekleme raporu

30 günde 18.420 işin %99,2'si başarılıdır. Başarısız 147 işin 103'ü legacy veri tabanına aittir. 96 başarısız iş ertesi gün başarılı olmuştur; 51'i açık ticket'tir.

E-03 | Restore testleri

Dosya sunucusu ve ana veri tabanı altı ay önce başarıyla dönmüştür. Test veri seti üretimin %3'üdür. Tam hacim performans testi yoktur. Şifreleme anahtarlarının kurtarma prosedürü test kapsamı dışındadır.

E-04 | DR planı

Plan son güncelleme: 2023. O tarihten sonra kimlik sağlayıcı ve ağ hizmeti değişmiştir. Çağrı ağacındaki üç yönetici şirketten ayrılmıştır. Teknik adımların bazıları günceldir.

LAB 08

DataCore - Backup, Disaster Recovery ve Business Continuity

Zorluk: İleri • Tahmini süre: 30-60 dakika • Rolünüz: Technology Risk Analyst

3. OLAYLAR VE KANITLAR - DEVAM

E-05 | Lokasyon bağımlılığı

İkinci veri merkezi ana platformu çalıştırabilir. DNS yönetimi, ayrıcalıklı erişim kasası ve anahtar yönetim sistemi birinci lokasyondadır. Bulut arşiv hesabının kurtarma e-postası da birinci lokasyon alan adındadır.

E-06 | Tabletop sonucu

Geçen yıl masa başı tatbikat yapılmıştır. İş birimleri katılmış, iletişim akışı başarılı bulunmuştur. Gerçek sistem geçişi yapılmamış ve ölçülen kurtarma süresi raporlanmamıştır.

E-07 | Müşteri taahhüdü

En büyük 20 müşterinin sözleşmesinde dört saatlik hizmet geri dönüş hedefi vardır. Operasyon yöneticisi tam geçişin 10-12 saat sürebileceğini tahmin eder; ölçüm bulunmamaktadır.

4. ÖĞRENCİNİN GÖREVLERİ

1. BIA, DR planı ve müşteri taahhütleri arasındaki tutarlılığı değerlendirin.
2. %99,2 başarı oranının tek başına neden yeterli olup olmadığını açıklayın.
3. Restore testinin kapsam ve temsil gücünü tartışın.
4. Tek lokasyon bağımlılıklarını hizmet zinciri üzerinde gösterin.
5. Güncel RTO/RPO doğrulaması için test planı hazırlayın.
6. Yönetimin dört saat iddiası hakkında hangi güvenceyi verebilirsiniz?
7. En önemli iki bulguyu yönetim dilinde yazın.

5. TESLİM EDİLMESİ BEKLENEN ÇIKTI

- Hizmet bağımlılık haritası
- RTO/RPO boşluk analizi
- Yedek ve restore kontrol sonucu
- 2 öncelikli audit finding
- Tatbikat ve iyileştirme yol haritası

ÇALIŞMANIZI TAMAMLADINIZ MI?

Bu vaka çalışmasının tek bir doğru cevabı olmayabilir. Önemli olan; riskleri nasıl değerlendirdiğiniz, kanıtları nasıl yorumladığınız ve vardığınız sonucu nasıl savunduğunuzdur.

Çalışmanızı tamamladıktan sonra çıktınızı:

volkan@grcustasi.com

adresine gönderebilirsiniz.

Gönderdiğiniz çalışmayı inceleyerek size geri dönüş sağlayacağım.

- Volkan Güler, CISA, CISM
GRC Ustası